

한국서부발전(주) 상임감사위원

통 보 · 권 고

제 목 ERP시스템 확정전표 접근권한 내부통제 필요
소 관 부 서 본사 및 사업소 전 처실
조 치 부 서 기획본부 △△△△실, ○○처 ●●●●부
구 분 보안관리
내 용

1. 업무개요

기획본부 △△△△실은 개인정보처리시스템을 운영 또는 이용함에 있어 접근권한의 오·남용을 통한 개인정보의 유·노출을 방지하고 정보주체 등의 권리를 보호하려는 목적으로 「개인정보보호 내부관리계획」을 운용하고 있으며, ○○처 ●●●●부는 출납담당 등의 채무회계에 관한 업무를 총괄하고 있다.

한편 우리 회사는 「출납업무처리기준」에 따라 거래처로 지급하는 공사·용역·구매대금, 전불금 등과 임직원에게 지급하는 출장비 등은 은행 계좌이체의 방법으로 지급하고 있다.

그리고 같은 기준 제10조에 따라 거래 사실이 발생한 부서에서 채무전표를 직접 작성하는데, 이때 명세서 등의 증빙서류를 첨부하도록 하고 있으며, 출납담당자는 채무전표에 첨부되어야 할 증빙서류가 제반요건을 모두 갖추었는지를 확인한 후 출납업무를 수행한다.

이러한 일련의 과정은 전사적 자원관리시스템(이하 “ERP시스템”이라 한다)을 통하여 이루어지고 있다.

2. 관계 법령 및 판단 기준

「개인정보보호 내부관리계획」 제3조(용어정의)에 따르면 “개인정보”란 살아있는 개인에 관한 정보로서 성명, 주민등록번호 및 영상 등을 통하여 개인을 알아볼 수 있는 정보(해당 정보만으로는 특정 개인을 식별할 수 없더라도 다른 정보와 쉽게 결합하여 식별할 수 있는 것을 포함한다. 이 경우 쉽게 결합할 수 있는지 여부는 다른 정보의 입수 가능성 등 개인을 알아보는 데 소요되는 시간, 비용, 기술 등을 합리적으로 고려하여야 한다)를 말한다.

그리고 같은 절차서 별첨2. “개인정보처리시스템별 접근권한 관리방안” 제6항에는 개인정보시스템 접근, 열람 등 모든 접근권한은 법령 또는 업무규정에 따라 허용된 자에 한하여 업무수행에 필요한 최소한의 범위로 부여하도록 되어 있다.

이에 따라 개인정보가 포함된 정보의 접근, 열람 등의 권한이 업무 수행과 무관한 자에게 허용되지 않도록 관리하여야 한다.

3. 감사결과 확인된 문제점

그런데 이번 종합감사를 통해 ERP시스템의 접근권한 통제 실태를 점검한 결과, 전 직원이 확정전표를 조회할 수 있어 [표 2]와 같이 중요 개인정보 또는 증빙으로 첨부한 열람자 제한 문서를 열람할 수 있는 사례가 확인되었다.

[표 2] 개인정보, 열람제한 문서가 포함된 전표 사례

전표번호	증빙일	전표제목	붙임문서
4100658350 등	2022.09.14. 등	퇴직금 중간정산 지급(직원이름)	열람자 제한문서
4100913449 등	2024.05.15. 등	명예퇴직금(직원이름)	퇴직금내역서
4100660005 등	2022.09.22. 등	(직원이름) 보건관리자 월급여 지급	급여내역서
4101229827 등	2025.09.24. 등	2025년도 1차 체험형인턴 급여(8월)	급여내역서

※ 자료: ERP시스템

그 결과 업무 수행과 무관한 직원들에게 개인정보나 접근제한 문서 등이 노출될 우려가 있다.

관계기관 의견

●●●●부 출납업무담당자는 감사 의견에 이견은 없으며, 현재 ERP 확정 전표 리스트 접근권한이 전 직원에게 부여되어 있지만, 소속되어 있는 부서에서 생성된 채무전표에 한하여 접근을 통제할 계획이라고 답변하였다.

그리고 △△△△실은 개인정보보호와 비공개 문서관리의 문서 보안을 위하여 채무전표 생성 시 개인정보 비식별화 등의 교육자료를 배포하고 전 직원의 보안 인식 교육을 강화하겠다고 하였다.

조치할 사항

○○처장은 ERP시스템 확정전표 접근권한을 통제할 수 있도록 ICT부서와 협조하여 해당 시스템 기능을 개선하시기 바랍니다. (통보)

△△△△실장은 전 직원을 대상으로 ERP시스템을 비롯한 정보시스템 내 개인정보보호와 문서보안과 관련한 교육을 적극 시행하시기 바랍니다. (권고)